DOCUMENTO DE CÁTEDRA N°18

TEMA: VECTORES DE ATAQUE EN INFRAESTRUCTURA FÍSICA: ANÁLISIS FORENSE DE STUXNET E INDUSTROYER

Apertura: 1.000 centrífugas y el código que mintió durante trece días

Entre 2009 y 2010, la planta de enriquecimiento de uranio de Natanz, Irán, sufrió la destrucción progresiva de aproximadamente mil de sus centrífugas IR-1, según estimaciones públicas de organismos como el Institute for Science and International Security. Los operadores de la planta observaban en sus pantallas HMI valores de proceso completamente normales: presión, temperatura y velocidad de rotación dentro de los parámetros esperados. Las centrífugas, sin embargo, se aceleraban y desaceleraban fuera de los límites mecánicos de diseño, sometiendo sus rotores a esfuerzos que terminaban en falla catastrófica.

El malware que causó esto, identificado en junio de 2010 por la empresa bielorrusa VirusBlokAda y bautizado Stuxnet, no atacó el HMI para mostrar datos falsos por accidente: lo hizo deliberadamente. Antes de modificar la velocidad de los variadores de frecuencia que controlan los motores de las centrífugas, Stuxnet grabó aproximadamente trece días de valores de proceso normales directamente desde los módulos de entrada del PLC Siemens S7-417. Luego, durante el ataque, reprodujo («replay») esa grabación hacia el sistema de monitoreo mientras enviaba, en paralelo, comandos maliciosos a los variadores de frecuencia reales.

Este es el mecanismo exacto que la Sección 1 del Documento N°17 anticipó con el caso Aurora: un ataque a la Integridad de la telemetría —el operador ve lo que el atacante quiere que vea, no lo que realmente sucede— combinado con un ataque a la Disponibilidad e Integridad del actuador físico. La diferencia con Aurora es que Stuxnet no fue un experimento controlado en un laboratorio: fue la primera arma cibernética documentada diseñada específicamente para causar destrucción física progresiva, sostenida en el tiempo y oculta a la supervisión humana.

Este documento cierra la Unidad 4 —y la materia— aplicando el marco doctrinal del Documento N°17 (la tríada AIC, la matriz de riesgo, la metodología CCE) al análisis forense de Stuxnet y de los dos incidentes de Ucrania conocidos como el ataque de diciembre de 2015 y el ataque Industroyer de diciembre de 2016. Estos casos, que han funcionado como hilo conductor de la materia desde la Unidad 1, son la evidencia empírica que valida cada concepto desarrollado en las dieciocho documentos de cátedra precedentes.

Ubicación en el Programa: Este Documento N°18 cierra la Unidad 4 y la asignatura Tecnología Operativa. Stuxnet fue presentado en la Unidad 1 como caso motivador de los fundamentos físicos y de hardware de control; los ataques a Ucrania fueron presentados en la Unidad 2 como hilo conductor de PLCs, RTUs y HMIs. Este documento retoma ambos casos y los analiza en profundidad técnica forense, aplicando el marco ICS Cyber Kill Chain y la doctrina AIC/CCE desarrollada en el Documento

N°17. El cierre de este documento incluye una síntesis de las lecciones doctrinales de las cuatro unidades de la materia.

OBJETIVOS DE APRENDIZAJE

- Aplicar el marco ICS Cyber Kill Chain (Etapa 1: Intrusión Cibernética; Etapa 2: Ataque ICS) al análisis forense de incidentes históricos de sabotaje industrial.
- Describir el mecanismo técnico del ataque Stuxnet sobre las centrífugas de Natanz, incluyendo la manipulación man-in-the-middle de la telemetría y la alteración de los variadores de frecuencia.
- Diferenciar los incidentes de Ucrania de diciembre de 2015 y diciembre de 2016 según su nivel de automatización, el malware utilizado y el objetivo sobre los relés de protección.
- Aplicar retrospectivamente el marco AIC y la metodología CCE (Documento N°17) a ambos casos, identificando qué controles de ingeniería habrían roto la cadena de ataque en cada etapa.
- Sintetizar las lecciones doctrinales de las cuatro unidades de la materia a la luz de la evidencia empírica que estos casos proveen sobre la convergencia IT/OT, el IoT/IIoT y la doctrina de riesgo OT.

1. MARCO DE ANÁLISIS FORENSE: EL ICS CYBER KILL CHAIN

El framework Cyber Kill Chain, desarrollado originalmente por Lockheed Martin para describir la secuencia de un ataque a sistemas IT, resulta insuficiente para analizar incidentes de sabotaje industrial: termina en el momento en que el adversario alcanza sus objetivos dentro de la red, sin contemplar que en OT el verdadero objetivo es producir un efecto sobre el proceso físico. Michael Assante y Robert M. Lee (SANS Institute) extendieron el modelo en 2015 al ICS Cyber Kill Chain, un framework de dos etapas construido precisamente a partir del análisis de Stuxnet y del incidente de Ucrania de diciembre de 2015: la Etapa 1 cubre la intrusión cibernética convencional, y la Etapa 2 —exclusiva de los ataques ICS— cubre el desarrollo, entrega y ejecución de la capacidad de ataque específica sobre el proceso físico.

Etapa	Fase	Objetivo del atacante	Ejemplo en Stuxnet o Industroyer
Etapa 1 Intrusión cibernética	Reconocimiento	Identificar el objetivo, su arquitectura de red, el modelo de PLC/HMI utilizado y los puntos de acceso potenciales.	Stuxnet: reconocimiento de la configuración específica de Natanz mediante inteligencia previa sobre el modelo de centrífugas y la disposición de cascadas.
Etapa 1	Armamento y entrega	Empaquetar el malware con el exploit y el mecanismo de entrega adecuado al entorno objetivo, frecuentemente air-gapped.	Stuxnet: worm USB con cuatro vulnerabilidades de día cero (incluyendo CVE-2010-2568, vulnerabilidad de acceso directo .LNK)

Etapa	Fase	Objetivo del atacante	Ejemplo en Stuxnet o Industroyer
			diseñado para propagarse sin conexión a internet.
Etapa 1	Explotación	Ejecutar el código malicioso explotando la vulnerabilidad identificada para obtener ejecución en el sistema objetivo.	Ucrania dic. 2015: explotación de macros maliciosas en documentos Office (spear-phishing) que instalaron BlackEnergy3 en estaciones de trabajo corporativas.
Etapa 1	Instalación / Modificación	Establecer persistencia y, cuando es posible, modificar componentes del sistema (drivers, certificados, configuración) para ocultar la presencia del malware.	Stuxnet: instalación de un rootkit en modo kernel firmado con certificados digitales robados de Realtek y JMicron, ocultando los archivos del malware del sistema operativo.
Etapa 1	Comando y Control (C2)	Establecer un canal de comunicación con la infraestructura del atacante para recibir actualizaciones, exfiltrar datos de reconocimiento o recibir órdenes de activación.	Ucrania dic. 2015: uso de credenciales VPN robadas para acceso remoto persistente a la red SCADA, permitiendo control interactivo en tiempo real por los operadores del ataque.
Etapa 2 Ataque ICS	Desarrollo y validación del ataque ICS	Desarrollar la lógica de manipulación específica del proceso físico objetivo y validarla, frecuentemente en un entorno de prueba que replica la instalación real.	Stuxnet: desarrollo y prueba de la lógica de manipulación de variadores de frecuencia, presuntamente validada en una cascada de centrífugas de prueba antes del despliegue operativo.
Etapa 2	Entrega e instalación de la capacidad ICS	Instalar el componente de ataque específico del proceso físico (payload ICS) en el controlador o sistema objetivo, distinto del malware de intrusión de la Etapa 1.	Industroyer (dic. 2016): instalación de módulos de protocolo IEC 101, IEC 104, IEC 61850 y OPC DA capaces de emitir comandos directos a los IED (Intelligent Electronic Devices) de la subestación.
Etapa 2	Ejecución e impacto sobre el proceso físico	Activar la capacidad de ataque ICS para producir el efecto físico deseado: apertura de breakers, manipulación de actuadores, desactivación de protecciones.	Industroyer: apertura automatizada de múltiples breakers en la subestación de Kyiv sin intervención humana en tiempo real, más la activación del módulo de denegación de servicio contra relés Siemens SIPROTEC.

El valor doctrinal del modelo de dos etapas es que cada una requiere capacidades de defensa distintas. La Etapa 1 es defendible con los controles clásicos de IT —segmentación, EDR, filtrado de correo— que la mayoría de las organizaciones ya conoce. La Etapa 2 solo es defendible con conocimiento específico del proceso OT: nadie sin comprensión de cómo opera un variador de frecuencia de centrífuga o un IED de subestación puede diseñar una detección efectiva contra esa etapa. Esta es precisamente la competencia que la materia Tecnología Operativa busca formar.

2. STUXNET: ANÁLISIS FORENSE DEL SABOTAJE A NATANZ

2.1. Componentes del payload y su función en la cadena de ataque

Stuxnet es, hasta la fecha, el malware ICS más analizado de la historia. El trabajo de ingeniería inversa de Ralph Langner y de los equipos de Symantec y Kaspersky entre 2010 y 2012 reconstruyó su funcionamiento con un nivel de detalle excepcional. La siguiente tabla sistematiza los componentes técnicos más relevantes desde la perspectiva de la Ciberdefensa OT:

Componente	Mecanismo técnico	Efecto sobre el proceso físico u organizativo
Worm USB con cuatro días cero	Propagación mediante archivos .LNK maliciosos en medios extraíbles (CVE-2010-2568) y tres vulnerabilidades adicionales de escalamiento de privilegios y ejecución remota, diseñadas para atravesar el air gap de Natanz sin requerir conexión a internet.	Demuestra que el aislamiento físico (air gap) no es una barrera absoluta cuando existe transferencia de medios extraíbles entre la red corporativa y la red de control, un vector de convergencia análogo al analizado en el Documento N°15.
Rootkit con certificados digitales robados	Componentes en modo kernel firmados con certificados legítimos sustraídos de Realtek Semiconductor y JMicron Technology, lo que permitió que el malware pasara los controles de verificación de firma de Windows sin generar alertas.	Evidencia un nivel de recursos de inteligencia y acceso a infraestructura de terceros propio de un actor estatal (Security Level 4 del ISA/IEC 62443, Doc. N°15, Sección 4.2), no replicable por un adversario oportunista.
Lógica de fingerprinting / targeting	El malware verificaba la presencia de una configuración específica del PLC Siemens S7-315-2 que coincidía con el número y disposición de variadores de frecuencia de las cascadas de centrífugas de Natanz antes de activar el payload destructivo.	El malware permanecía inerte en cualquier sistema que no coincidiera con esa huella técnica específica, lo que demuestra un diseño de precisión orientado a minimizar el daño colateral —objetivo que, como se analiza en la Nota de Ciberdefensa 1, no se cumplió completamente.
Man-in-the-middle de telemetría (PLC S7-417)	Grabación de aproximadamente trece días de valores normales de los módulos de entrada del PLC, seguida de la reproducción («replay») continua de esos valores	Ataque directo a la Integridad de la telemetría (Doc. N°17, Sección 1.1): el operador humano, última barrera de detección, veía exactamente los valores que el

Componente	Mecanismo técnico	Efecto sobre el proceso físico u organizativo
	hacia el sistema de monitoreo WinCC mientras el ataque estaba activo.	atacante eligió mostrarle. Ningún proceso de supervisión humana pudo detectar el ataque por esta vía.
Manipulación de variadores de frecuencia	Comandos maliciosos enviados a los variadores de frecuencia (de fabricantes Vacon y Fararo Paya) que controlan la velocidad de rotación de los motores de las centrífugas, alterando su velocidad muy por encima y muy por debajo de los límites de diseño de forma cíclica.	Esfuerzo mecánico sostenido sobre los rotores de las centrífugas IR-1, que terminaba en falla por fatiga del material. El efecto era progresivo y distribuido en el tiempo, dificultando la atribución a una causa única durante meses.

⚠ Nota de Ciberdefensa — La precisión imperfecta: Stuxnet escapó de Natanz y se propagó a más de cien mil sistemas

El diseño de Stuxnet incluía lógica de targeting específica precisamente para minimizar el riesgo de daño colateral: el payload destructivo solo se activaba si el sistema coincidía con la huella técnica exacta de las cascadas de Natanz. Sin embargo, el componente de propagación (el worm USB) no tenía esa restricción: una vez liberado, se propagó sin control mediante medios extraíbles y redes corporativas, alcanzando, según estimaciones de Symantec, más de cien mil sistemas Windows en más de cien países, incluyendo instalaciones industriales sin ninguna relación con el programa nuclear iraní.

La lección doctrinal para la Ciberdefensa es doble. Primero, ningún arma cibernética diseñada para propagarse por medios extraíbles puede garantizar contención total: el mismo mecanismo que le permite atravesar un air gap es el que elimina el control sobre su alcance final. Segundo, y más relevante para instalaciones de Defensa: cualquier sistema OT en el mundo pudo, en teoría, haber recibido una copia inerte de Stuxnet sin saberlo. La presencia de malware dirigido a un tercero en la propia infraestructura —aunque no active su payload destructivo por no coincidir la huella técnica— es en sí misma una violación de la integridad del sistema que debe ser detectada y remediada, no ignorada por considerarse «no dirigida a nosotros».

Esta es la razón por la que el desarrollo de capacidades ofensivas cibernéticas contra sistemas OT conlleva un riesgo de proliferación asimétrico que no tiene equivalente directo en armas convencionales: el código, una vez liberado, no respeta fronteras ni objetivos originales.

3. INDUSTROYER Y LA EVOLUCIÓN HACIA EL ATAQUE AUTOMATIZADO EN UCRANIA

El conflicto en Ucrania produjo dos ataques distintos contra la red eléctrica, separados por exactamente un año, que constituyen el experimento natural más claro sobre la evolución de la capacidad ofensiva ICS de un mismo actor (atribuido por la comunidad de inteligencia de amenazas al grupo conocido como Sandworm). Distinguir ambos incidentes con precisión es indispensable: la literatura de cátedra de unidades anteriores los ha referenciado de forma conjunta como hilo conductor; este documento los separa para el análisis forense detallado.

3.1. Diciembre de 2015: el ataque con operador humano

El 23 de diciembre de 2015, tres compañías distribuidoras de energía de Ucrania occidental (Prykarpattyaoblenergo, Chernivtsioblenergo y Kyivoblenergo) sufrieron cortes de energía que afectaron a aproximadamente 225.000 clientes durante un período de una a seis horas, según el reporte conjunto de SANS Institute y E-ISAC (2016). El vector de acceso inicial fue spear-phishing con macros maliciosas en documentos Office, que instaló el malware BlackEnergy3 en estaciones de trabajo corporativas. Desde allí, los atacantes obtuvieron credenciales VPN legítimas y accedieron de forma interactiva al entorno SCADA.

El elemento distintivo de este ataque es que la apertura de los breakers de las subestaciones fue ejecutada manualmente por los atacantes, operando en tiempo real el software HMI/SCADA legítimo mediante sesiones de escritorio remoto, como si fueran operadores autorizados. El ataque incluía además el componente destructivo KillDisk, que borró el master boot record de los servidores SCADA afectados para dificultar la respuesta al incidente, y un ataque de denegación de servicio telefónico contra los centros de llamada de las empresas para retrasar que los clientes reportaran el corte.

3.2. Diciembre de 2016: Industroyer / CRASHOVERRIDE

Exactamente un año después, el 17 de diciembre de 2016, una subestación de transmisión en Kyiv sufrió un corte de energía de aproximadamente una hora de duración. El malware utilizado, identificado por ESET y Dragos como Industroyer (también denominado CRASHOVERRIDE), representa un salto cualitativo de sofisticación respecto al incidente del año anterior: en lugar de depender de un operador humano manipulando el HMI, Industroyer incluye módulos de payload capaces de comunicarse directamente con los dispositivos de campo utilizando los protocolos ICS nativos de la subestación —IEC 60870-5-101, IEC 60870-5-104, IEC 61850 y OPC Data Access—, emitiendo órdenes de apertura de breaker de forma automática, sin intervención humana en el momento de la ejecución.

El componente más relevante de Industroyer desde la perspectiva doctrinal de este documento es su módulo de denegación de servicio contra relés de protección Siemens SIPROTEC, que explotaba la vulnerabilidad CVE-2015-5374 para dejar inoperativos esos dispositivos mediante el envío de paquetes especialmente formados al puerto UDP 50000. Los relés de protección son, en términos del Documento N°17, exactamente el tipo de control de ingeniería de «Fase 4» —el equivalente eléctrico del relé de sincronía de fase del caso Aurora— diseñado para actuar independientemente del sistema de control digital y aislar la falla antes de que se propague. Al atacar directamente esa capa de protección, Industroyer no solo manipuló el proceso: intentó eliminar la barrera de seguridad que existe precisamente para casos como este.

Característica	Diciembre 2015 (BlackEnergy3 / KillDisk)	Diciembre 2016 (Industroyer / CRASHOVERRIDE)
Mecanismo de apertura de breakers	Manual: los atacantes operaron interactivamente el HMI/SCADA legítimo mediante sesiones de escritorio remoto con credenciales robadas, como si fueran operadores autorizados.	Automatizado: módulos de payload con protocolo ICS nativo emitieron comandos de apertura directamente a los IED de campo sin operador humano en el momento de la ejecución.

Característica	Diciembre 2015 (BlackEnergy3 / KillDisk)	Diciembre 2016 (Industroyer / CRASHOVERRIDE)
Malware principal	BlackEnergy3 (acceso inicial) + KillDisk (destrucción de MBR para dificultar la respuesta al incidente).	Industroyer / CRASHOVERRIDE: framework modular con backdoor, módulos de protocolo ICS intercambiables y componente wiper propio.
Protocolos ICS soportados por el malware	Ninguno específico: el ataque dependió de la interfaz HMI legítima, no de comunicación directa por protocolo industrial.	Módulos dedicados para IEC 60870-5-101, IEC 60870-5-104, IEC 61850 y OPC DA: el malware «habla» el protocolo ICS nativamente.
Objetivo sobre relés de protección	No identificado en este incidente.	Módulo de denegación de servicio específico contra relés Siemens SIPROTEC (CVE-2015-5374), atacando directamente la capa de protección de Fase 4 (Doc. N°17).
Alcance del impacto	Aproximadamente 225.000 clientes sin energía, entre una y seis horas, en tres regiones de Ucrania occidental.	Una subestación de transmisión en Kyiv, impacto geográfico más acotado pero de mayor sofisticación técnica.
Restauración del servicio	Manual: los operadores viajaron físicamente a las subestaciones para restaurar el servicio operando los breakers manualmente, dado que el sistema SCADA estaba comprometido.	Manual: los operadores restauraron el servicio mediante operación manual local en aproximadamente 75 minutos, sin depender del sistema SCADA automatizado comprometido.

Nota de Ciberdefensa — Cuando el adversario estudia tu Fase 4: el ataque a los relés SIPROTEC como lección de CCE

El Documento N°17 (Sección 3, Nota de Ciberdefensa 3) presenta el override manual y los mecanismos de protección independientes del sistema digital como la mitigación de «Fase 4» de la metodología CCE: el control de ingeniería que garantiza que, incluso si el atacante controla el sistema digital, el daño catastrófico no puede ocurrir. Industroyer demuestra que un adversario sofisticado también aplica un razonamiento equivalente, en sentido inverso: si la última barrera de protección son los relés SIPROTEC, atacar esos relés directamente neutraliza la mitigación antes de que pueda activarse.

Esto no invalida la doctrina CCE: la confirma. El hecho de que Industroyer incluyera un módulo específico para atacar relés de protección es evidencia de que un adversario estatal con tiempo y recursos identifica las mitigaciones de Fase 4 de su objetivo y diseña capacidades para neutralizarlas específicamente. La conclusión doctrinal correcta no es abandonar los controles de ingeniería independientes del estado cibernético, sino protegerlos con el mismo rigor que se aplica al sistema de control primario: los relés de protección deben estar en su propia Security Zone (Doc. N°15, Sección 4.2), con su firmware actualizado contra CVEs conocidos y sin exposición a la misma red que el sistema SCADA que protegen.

Para instalaciones de Defensa, la lección es explícita: si un sistema crítico depende de un mecanismo de protección de última línea (interlock mecánico, relé de protección, override manual), ese mecanismo debe asumirse como un objetivo de ataque por derecho propio, no como una garantía pasiva que el adversario ignorará.

4. SÍNTESIS DOCTRINAL: AIC Y CCE APLICADOS RETROSPECTIVAMENTE

Aplicando el marco del Documento N°17 a los tres casos analizados, emerge un patrón consistente: en los tres, la propiedad de seguridad violada con mayor consecuencia no fue la Confidencialidad —la prioridad clásica de IT— sino la Disponibilidad y la Integridad, exactamente en el orden que predice la tríada AIC.

Caso	Propiedad AIC violada principalmente	Mecanismo técnico	Categoría de consecuencia (Doc. N°17, Sección 2.3)
Stuxnet (2009–2010)	Integridad (telemetría falsificada) + Disponibilidad/Integridad del actuador	Replay de 13 días de valores normales al monitoreo + manipulación de variadores de frecuencia fuera de los límites de diseño.	Estratégica/Misión (degradación del programa de enriquecimiento) y Financiera (reemplazo de aproximadamente mil centrífugas).
Ucrania, dic. 2015	Disponibilidad (apertura manual de breakers)	Operación interactiva del HMI legítimo con credenciales robadas; destrucción de MBR para dificultar la respuesta.	Operacional/Misión (225.000 clientes sin energía) y Reputacional (primera pérdida de energía atribuida públicamente a un ciberataque).
Industroyer, dic. 2016	Disponibilidad (apertura automatizada) + Integridad de la capa de protección (DoS sobre SIPROTEC)	Módulos de protocolo ICS nativo para apertura directa de breakers; DoS dirigido a relés de protección (CVE-2015-5374).	Operacional/Misión y, potencialmente, Seguridad humana si la falla de protección hubiera coincidido con una condición de falla eléctrica real no relacionada con el ataque.

La aplicación retrospectiva de la matriz de riesgo (Doc. N°17, Sección 2.2) a estos tres casos confirma el punto doctrinal central de esa sección: los tres eventos tenían, antes de ocurrir, una probabilidad estimada como baja por los defensores —un ataque de capacidad estatal contra una instalación nuclear o una red eléctrica nacional no era el escenario de planeamiento más frecuente— pero una consecuencia catastrófica. Los tres caen en el cuadrante superior derecho de la matriz: el que un modelo de riesgo centrado solo en probabilidad subestima sistemáticamente, y el que la doctrina de Ciberdefensa OT debe priorizar por diseño.

La aplicación retrospectiva de las cuatro fases de CCE (Doc. N°17, Sección 3) revela qué mitigación de ingeniería habría roto cada cadena de ataque: para Stuxnet, un límite mecánico de velocidad en los variadores de frecuencia, independiente del comando

digital recibido, habría impedido la destrucción de las centrífugas incluso con la telemetría falsificada. Para el incidente de 2015, un mecanismo de autenticación multifactor en el acceso VPN habría interrumpido la cadena en la Etapa 1, antes de alcanzar el SCADA. Para Industroyer, la segmentación de los relés SIPROTEC en su propia Security Zone, fuera de alcance de los módulos de protocolo ICS del malware, habría preservado la última barrera de protección. En los tres casos, la mitigación más robusta no depende de prevenir el acceso del adversario, sino de garantizar que, aun con acceso, el daño catastrófico no pueda materializarse.

Nota de Ciberdefensa — 75 minutos: la prueba empírica de que la Fase 4 de CCE funciona

El Documento N°17 presenta la metodología CCE como doctrina prospectiva: diseñar mitigaciones de ingeniería antes de que ocurra un incidente. El incidente de Industroyer provee la confirmación empírica más clara disponible de que esa doctrina funciona en la práctica, incluso cuando se aplica de forma no planificada. A pesar de que el malware logró abrir los breakers automáticamente y atacar los relés de protección, los operadores de la subestación de Kyiv restauraron el servicio en aproximadamente 75 minutos mediante operación manual local, sin depender del sistema SCADA comprometido.

Esa capacidad de restauración manual no fue diseñada como contramedida cibernética: existía porque la infraestructura eléctrica ucraniana, como la de muchas redes con componentes legacy, conservaba la capacidad de operación manual local de los breakers independientemente del sistema de control digital. Esa redundancia —exactamente el tipo de capacidad que la Nota de Ciberdefensa 3 del Documento N°17 recomienda preservar en instalaciones de Defensa durante la modernización IT/OT— fue la diferencia entre una hora de interrupción y una crisis prolongada.

La lección para cualquier proyecto de modernización de infraestructura crítica o militar es directa: antes de eliminar un mecanismo de operación manual o analógico en nombre de la eficiencia, debe evaluarse explícitamente —mediante la Fase 1 de CCE— si ese mecanismo es la última barrera ante un escenario de consecuencia catastrófica. La evidencia de Kyiv 2016 sugiere que, frecuentemente, lo es.

5. CIERRE DE UNIDAD 4 Y DE LA MATERIA

Este documento cierra no solo la Unidad 4 sino el recorrido completo de Tecnología Operativa. La siguiente tabla sintetiza cómo Stuxnet e Industroyer —los dos casos que han acompañado la materia desde su primera unidad— validan empíricamente la lección doctrinal central de cada etapa del programa:

Unidad / Documentos	Tema central	Lección validada por Stuxnet e Industroyer en este documento
Unidad 1 (Docs. 1–4)	Fundamentos físicos y hardware de control: sensores, actuadores, diodos, transistores.	Stuxnet no atacó software abstracto: atacó variadores de frecuencia, motores y rotores físicos. Sin comprender cómo un comando digital se traduce en movimiento mecánico, ningún analista puede entender por qué ese ataque destruyó hardware real.
Unidad 2 (Docs. 5–8)	PLCs, RTUs, HMIs y la lógica de	El ataque de diciembre de 2015 fue posible porque el HMI, diseñado para que un

Unidad / Documentos	Tema central	Lección validada por Stuxnet e Industroyer en este documento
	automatización, con Ucrania 2015 como caso conductor.	operador controle el proceso, no distingue entre un operador legítimo y un atacante con credenciales robadas operando la misma interfaz.
Unidad 3 (Docs. 9–14)	SCADA, DCS, protocolos industriales (Modbus, DNP3) y aplicaciones verticales (BMS, transporte, PACS).	Industroyer «habla» los mismos protocolos sin autenticación estudiados en esta unidad (IEC 101, IEC 104, IEC 61850): la ausencia de autenticación de protocolo es la vulnerabilidad estructural que permite el comando automático no autorizado.
Unidad 4, Doc. 15 Convergencia IT/OT	Modelo Purdue, vectores de erosión, Industria 4.0.	El worm USB de Stuxnet explotó exactamente el tipo de vector de convergencia no controlada —transferencia de medios entre redes— que el Documento N°15 cataloga como erosión de la segmentación Purdue.
Unidad 4, Doc. 16 IoT e IIoT	Protocolos ligeros, taxonomía de dispositivos, desafíos estructurales.	La dificultad de remediar vulnerabilidades en sistemas de ciclo de vida largo, analizada con el caso URGENT/11, es la misma razón estructural por la que las centrífugas IR-1 de Natanz nunca recibieron un parche que las protegiera del ataque de variadores de frecuencia.
Unidad 4, Doc. 17 Doctrina AIC / CCE	Inversión CIA→AIC, matriz de riesgo, Cyber-Informed Engineering.	Este mismo documento (N°18) es la validación empírica directa: Stuxnet e Industroyer son, retrospectivamente, ejemplos de libro de la doctrina AIC y de la necesidad de mitigaciones de ingeniería independientes del estado cibernético del sistema.

La conclusión doctrinal final de la materia es la misma que estableció el caso Aurora en la apertura del Documento N°17 y que Stuxnet e Industroyer confirman con evidencia real: los sistemas OT no son servidores IT con distinto software, y la Ciberdefensa que los protege no puede ser una traducción directa de la seguridad de la información. Requiere comprender el proceso físico controlado, priorizar la disponibilidad y la integridad sobre la confidencialidad, diseñar mitigaciones de ingeniería que no dependan exclusivamente del estado cibernético del sistema, y asumir que la consecuencia, no solo la probabilidad, debe gobernar la decisión de riesgo. Esa es la competencia profesional que esta materia buscó formar a lo largo de sus cuatro unidades.

6. ACTIVIDADES DE VERIFICACIÓN Y ANÁLISIS

1. Stuxnet mapeado al ICS Cyber Kill Chain

Utilizando la Tabla 1 de la Sección 1 como guía, reconstruya la cadena de ataque completa de Stuxnet contra Natanz.

(a) Para cada una de las ocho fases del ICS Cyber Kill Chain, identifique el componente específico de Stuxnet (Tabla 2, Sección 2.1) que corresponde a esa fase.

(b) Identifique cuál de las ocho fases representaba, en su opinión fundamentada, la mejor oportunidad de detección o interrupción por parte de los defensores de Natanz, considerando las capacidades de detección disponibles en 2009-2010.

(c) Explique por qué la fase de «Ejecución e impacto sobre el proceso físico» fue, en este caso, la fase más difícil de detectar en tiempo real, vinculando su respuesta con el mecanismo de man-in-the-middle de telemetría de la Sección 2.1.

2. Comparación forense — Ucrania 2015 vs. Industroyer 2016

Utilizando la Tabla 3 de la Sección 3.2, analice la evolución de capacidad entre ambos incidentes atribuidos a Sandworm.

(a) Identifique qué capacidad técnica específica de Industroyer (2016) habría sido innecesaria en el incidente de 2015, y explique qué inversión de desarrollo representa esa capacidad para el atacante.

(b) El ataque de 2015 dependió de un operador humano en tiempo real; el de 2016 fue automatizado. Argumente, desde la perspectiva de la detección defensiva (Doc. N°15, Sección 4.1, función Detect del NIST CSF), cuál de los dos modelos de ataque es más difícil de detectar mediante un IDS OT y por qué.

(c) El módulo de DoS contra relés SIPROTEC fue el componente más sofisticado de Industroyer. Proponga dos controles de segmentación de red (Doc. N°15, Sección 4.2, Security Zones y Conduits) que habrían aislado los relés de protección del alcance de ese módulo.

3. Diseño retrospectivo de CCE para las centrífugas de Natanz

Aplique las cuatro fases de Cyber-Informed Engineering (Doc. N°17, Sección 3) como si se hubiera realizado un análisis CCE en la planta de Natanz antes de 2009, sin conocimiento previo del ataque Stuxnet.

(a) Fase 1 (Priorización de consecuencias): identifique el evento de consecuencia más catastrófica que el sistema de control de las centrífugas podría sufrir, sin asumir un origen cibernético específico.

(b) Fase 2 (Análisis de sistema de sistemas): trace la ruta técnica que el ataque real utilizó (PLC → variador de frecuencia → motor → rotor) e identifique en qué punto de esa cadena un comando malicioso, legítimo o no, podría producir el evento identificado en (a).

(c) Fases 3 y 4 (Focalización y mitigación): proponga un mecanismo de ingeniería —análogo al relé de sincronía de fase del caso Aurora— que limite mecánicamente la velocidad máxima y mínima de los motores de las centrífugas, independientemente del comando recibido por el variador de frecuencia. Explique por qué este control habría sido efectivo incluso con la telemetría falsificada por el ataque real.

4. Caso integrador final — capstone de la materia: Base Logística Sur bajo ataque

Retome la arquitectura de Base Logística Sur (AP N°15): generadores de emergencia con PLCs, sensores IIoT de mantenimiento predictivo con gateway 4G, BMS convergente y relés de protección del sistema eléctrico de la instalación. Un adversario con capacidad estatal (Security Level 4, ISA/IEC 62443) planea un ataque combinando elementos de Stuxnet e Industroyer.

(a) Diseñe la cadena de ataque completa utilizando el ICS Cyber Kill Chain de la Sección 1: para cada fase, identifique qué vector de convergencia (Doc. N°15) o vulnerabilidad de dispositivo IIoT (Doc. N°16) explotaría el adversario, inspirándose en los mecanismos reales de Stuxnet e Industroyer.

(b) Clasifique el riesgo del escenario diseñado en la matriz de probabilidad/consecuencia (Doc. N°17, Sección 2.2), justificando la clasificación con las categorías de consecuencia de la Sección 2.3 de ese documento.

(c) Proponga, para cada fase del Kill Chain diseñada en (a), un control específico de alguno de los cuatro documentos de la Unidad 4 que interrumpiría la cadena en ese punto, incluyendo al menos una mitigación de ingeniería de Fase 4 de CCE independiente del estado cibernético del sistema.

7. GLOSARIO MÍNIMO

Término	Definición
BlackEnergy3	Malware utilizado en el acceso inicial del ataque a la red eléctrica ucraniana de diciembre de 2015, entregado mediante spear-phishing con macros maliciosas en documentos Office.
CRASHOVERRIDE	Denominación alternativa de Industroyer utilizada por la firma Dragos en su análisis técnico del ataque a la subestación de Kyiv de diciembre de 2016.
Fingerprinting / lógica de targeting	Mecanismo mediante el cual un malware verifica características específicas del sistema objetivo (modelo de PLC, configuración de dispositivos) antes de activar su payload destructivo, limitando en teoría su efecto a la instalación prevista.
ICS Cyber Kill Chain	Framework de análisis forense de dos etapas (Intrusión Cibernética y Ataque ICS) desarrollado por Michael Assante y Robert M. Lee (SANS Institute, 2015) a partir del análisis de Stuxnet y del incidente de Ucrania de 2015.
Industroyer	Malware modular identificado por ESET en 2017, responsable del ataque a la subestación de Kyiv de diciembre de 2016. Incluye módulos de protocolo ICS nativo (IEC 101, IEC 104, IEC 61850, OPC DA) y un módulo de denegación de servicio contra relés Siemens SIPROTEC.
KillDisk	Componente destructivo utilizado en el ataque de diciembre de 2015 que borra el master boot record de los sistemas afectados, dificultando la respuesta al incidente y la recuperación.
Man-in-the-middle de telemetría	Técnica utilizada por Stuxnet consistente en grabar valores normales del proceso y reproducirlos («replay») al sistema de monitoreo mientras se ejecuta una manipulación maliciosa real sobre el actuador, ocultando el ataque a la supervisión humana.
Natanz	Planta de enriquecimiento de uranio de Irán, objetivo del ataque Stuxnet entre 2009 y 2010, donde aproximadamente mil centrífugas IR-1 resultaron destruidas según estimaciones públicas.

Término	Definición
Sandworm	Denominación de inteligencia de amenazas atribuida al actor responsable de los ataques a la red eléctrica ucraniana de diciembre de 2015 y diciembre de 2016.
SIPROTEC (relés)	Familia de relés de protección eléctrica de Siemens, objetivo del módulo de denegación de servicio de Industroyer mediante la explotación de CVE-2015-5374, dejando inoperativa la última barrera de protección de la subestación.
Stuxnet	Malware identificado en junio de 2010, diseñado para sabotear el programa de enriquecimiento de uranio de Irán mediante manipulación de variadores de frecuencia y falsificación de telemetría en PLCs Siemens S7-315/417. Considerado la primera arma cibernética documentada con efecto de destrucción física deliberada.
Worm USB	Mecanismo de propagación de Stuxnet mediante medios extraíbles, diseñado para atravesar redes air-gapped sin conexión a internet, explotando cuatro vulnerabilidades de día cero.

REFERENCIAS BIBLIOGRÁFICAS

Langner, R. (2013). To Kill a Centrifuge: A Technical Analysis of What Stuxnet's Creators Tried to Achieve. The Langner Group.

Falliere, N., Murchu, L. O., & Chien, E. (2011). W32.Stuxnet Dossier (Version 1.4). Symantec Security Response.

Assante, M. J., & Lee, R. M. (2015). The Industrial Control System Cyber Kill Chain. SANS Institute, Whitepaper.

Electricity Information Sharing and Analysis Center (E-ISAC) & SANS Industrial Control Systems. (2016). Analysis of the Cyber Attack on the Ukrainian Power Grid: Defense Use Case.

Cherepanov, A. (2017). WIN32/INDUSTROYER: A New Threat for Industrial Control Systems. ESET Research.

Dragos, Inc. (2017). CRASHOVERRIDE: Analysis of the Threat to Electric Grid Operations. Dragos Threat Intelligence.

Zetter, K. (2014). Countdown to Zero Day: Stuxnet and the Launch of the World's First Digital Weapon. Crown Publishers.

Assante, M. J., & Lee, R. M. (Idaho National Laboratory). Comunicaciones técnicas sobre el Aurora Generator Test, referenciadas en el Doc. de Cátedra N°17, FADENA (2026).

Cátedra Tecnología Operativa (2026). Documentos de Cátedra N°15 (Convergencia IT/OT), N°16 (IoT e IIoT) y N°17 (Doctrina AIC/CCE). FADENA.